SCAMSHIELD

ScamShield Main

A scalable, privacy-conscious fraud-protection platform

LONG-TERM PRODUCT BLUEPRINT

Product concept and implementation plan

Prepared as a two-track project: a six-hour hackathon demonstrator and a scalable long-term fraud-protection platform.

Design principle: build a focused first slice without discarding the larger product vision.

1. Vision

ScamShield aims to become a cross-platform fraud-protection and intelligence network. A single intelligence core would support the consumer app, SMS protection where operating systems permit it, audio transcription and scam analysis, approved social-platform bots, business tools and future enterprise integrations.

The core idea is to go beyond classifying one suspicious message. ScamShield should explain the evidence, connect related indicators when justified, help users verify sensitive requests and guide them toward safe next steps.

- Core principle 1: explain why content was flagged.
- Core principle 2: show uncertainty and distinguish evidence from inference.
- Core principle 3: minimise data collection and require appropriate consent.
- Core principle 4: build modularly so features can be introduced without redesigning the entire platform.

2. Main product modules

- **Consumer app:** message, URL, document and payment-request checks; report history; safety guidance; account and privacy controls.
- **SMS Shield:** screen suspicious SMS where supported by the device and operating system, using narrow permissions and approved filtering roles.
- **Voice Intelligence:** user-consented audio upload, transcription, timestamps and analysis of suspicious requests. Live-call access depends on platform support, consent and law.
- **Social connector framework:** separate integrations for supported group bots, business inboxes and social platforms, using official APIs and granted permissions.
- **Scam DNA graph:** connect domains, URLs, phone numbers, payment identifiers, impersonated organisations and report patterns, preserving source and confidence for each link.
- **Pre-Payment Guardian:** help verify payment requests; actual transaction interception or blocking requires a real integration with a participating provider.
- **Business and enterprise:** incident management, investigation timelines, verified contact registries, alerts, reporting and API access.
- **Recovery assistant:** practical steps after a suspected loss, evidence preservation and directions to legitimate official channels.
- **Multilingual intelligence:** validated support for English and selected Ghanaian languages, expanded only after language-specific testing.
- **Privacy and trust:** consent, minimisation, retention limits, audit logs, correction paths and false-positive review.

3. System architecture

The recommended first production architecture is a modular backend rather than many microservices. Clear module boundaries make it possible to split high-load components later, when there is evidence that doing so is useful.

- **Client applications:** responsive web app first; Android app, business dashboard and other clients as the roadmap advances.
- **API and identity layer:** authentication, permission checks, rate limiting, consent records and audit events.
- **Ingestion adapters:** normalise text, URLs, documents/OCR, audio transcripts and connector events.
- **Analysis engine:** deterministic rules, curated threat feeds and model-assisted classification behind replaceable adapters.

- **Intelligence store:** PostgreSQL for users, incidents, indicators and analysis records; introduce graph infrastructure when relationship queries justify it.
- **Response layer:** risk band, evidence, confidence, missing evidence and recommended action.
- **Operations:** monitoring, evaluation, model/rule versioning, feedback review, incident response and retention enforcement.

4. Proposed technology stack

Layer	Initial direction	Reason
Frontend	React / Next.js	Reusable interface for consumer and business workflows.
Backend	Python / FastAPI	Clear API structure and convenient AI ecosystem.
Database	PostgreSQL	Relational data, cases, reports and indicator provenance.
AI and audio	Provider adapters for language models and transcription	Swap providers without rewriting the product.
Background jobs	Queue for audio/document processing	Handle longer work without blocking requests.
Threat intelligence	Curated feeds with timestamps and source metadata	Support evidence freshness and source traceability.

5. API and data model candidates

- **Possible API routes:** `POST /v1/analyze/message`, `POST /v1/analyze/url`, `POST /v1/analyze/audio`, `POST /v1/reports`, `GET /v1/reports`, and `GET /v1/campaigns/{campaign_id}`. These are proposals, not implemented endpoints in the static hackathon demo.
- **users:** account details and consent preferences.
- **incidents:** report, case status, timestamps and review outcomes.
- **indicators:** normalised URL, domain, phone number, email or payment identifier, stored only when necessary.
- **incident_indicators:** relationships with source, confidence and explanation.
- **analyses:** rule/model version, risk band, reasons, timestamp and feedback.
- **connectors:** provider, permitted scopes, token reference and integration status; never store platform passwords.
- **audit_events and feedback:** access records, user corrections and review outcomes.

6. Roadmap

- **Stage 1 — Hackathon proof:** message and URL checks, explanations, local report feed and simulated social bot.
- **Stage 2 — Private alpha:** backend API, secure database, authentication, model adapter, curated threat feeds, privacy controls and deletion workflow.
- **Stage 3 — Consumer product:** mobile experience, consent-based audio analysis, supported SMS capabilities, report history and recovery guidance.
- **Stage 4 — Integrations:** first approved social/group bot connector, business inbox integration and enterprise dashboard.
- **Stage 5 — Network scale:** richer graph analysis, privacy-preserving threat sharing, payment-provider partnerships, language expansion and ongoing model evaluation.

7. Privacy, safety and quality requirements

- Request clear consent before processing private messages, files or audio.
- Minimise collection, redact personal information where feasible and enforce retention limits.
- Never request or expose passwords, PINs or one-time passcodes.
- Treat community reports as unverified until corroborated; do not publicly accuse individuals based on a single report.
- Record the source and freshness of threat indicators, and distinguish confirmed facts from inferences.
- Provide a route to correct false positives and review consequential decisions.
- Use official platform APIs and narrowly scoped permissions; do not bypass encryption or access controls.
- Evaluate precision, recall, false-positive rate, latency and whether users understand the warnings.
- Make clear that 'no known threat detected' does not mean 'safe'.
- Review applicable privacy, data-protection, recording-consent and platform rules before launch in each market.

8. Business model candidates

- Freemium consumer product with optional family plan.
- Business subscription for inbox monitoring and case management.
- Enterprise contracts for larger organisations and financial institutions.
- API access for authorised partners.
- Validate customer demand and willingness to pay before committing to pricing.

9. Non-negotiable implementation boundary

Do not promise universal SMS access, automatic call recording, access to all private social messages or payment blocking until a specific operating system, platform or provider supports the capability and the necessary permissions and legal basis are in place.

The hackathon MVP is a proof of workflow, not the production security system. Its local storage and heuristic scoring should not be carried into public deployment without secure backend design, evaluation and operational controls.